

CPF Gateway 매뉴얼

- [CPF Gateway 매뉴얼](#)
 - [1. Gateway 선택 기준](#)
 - [2. 설치](#)
 - [3. Server Group · Target · Discovery](#)
 - [4. Route · Predicate · Filter · Rewrite](#)
 - [5. Authentication · Authorization](#)
 - [5.1 Default Deny 공개 원칙](#)
 - [6. HMAC · Audience · Body Hash · Nonce](#)
 - [7. SSRF · TLS](#)
 - [8. Timeout Budget](#)
 - [9. Retry · Circuit Breaker · Bulkhead · Rate Limit](#)
 - [10. Idempotency · Attempt Ledger](#)
 - [11. UNKNOWN RESULT](#)
 - [12. Validate](#)
 - [13. Approval · Publish](#)
 - [14. ACK · NACK · Partial Apply](#)
 - [15. LKG · Rollback](#)
 - [16. Scale-out · Drift · Reconciliation](#)
 - [17. Probe · Health](#)
 - [18. ADM 운영](#)
 - [19. 장애 Runbook](#)
 - [Route NACK](#)
 - [Response Loss](#)
 - [Partial Apply](#)
 - [SSRF/TLS 차단](#)
 - [20. Route 게시 · 응답 유실 통합 실습](#)
 - [21. 완료 체크리스트](#)
 - [22. Trusted Proxy · Header Policy](#)
 - [23. Streaming · Client Disconnect](#)
 - [24. Rate Limit · Quota](#)
 - [25. Multi-instance Correlation](#)
 - [26. Gateway Artifact Trust](#)
 - [27. Gateway 제품과 Reference 경계](#)

- [28. Route 생명주기](#)
- [29. transactionId · Attempt 계보](#)
- [30. Attempt Ledger와 응답 유실](#)
- [31. SSRF · TLS · Trusted Proxy](#)
- [32. Scale-out · Canary · Drift](#)
- [33. Gateway 운영 인수 Gate](#)

34. 현재 제품 검증 상태와 R6J 사용 경계

CPF Gateway 매뉴얼

기준 Repository: https://github.com/freeangelsun/202412_01_CPF 기준 Branch: master 문서 콘텐츠 기준 Commit: cd5baccb02245a980e5998aa0dc9bac579fc019f (07_04) 기준일: 2026-08-08 Asia/Seoul 기준 Commit: 현재 master 구현 기준 문서. Product Surface · Starter · Tool · EDU 식별자는 아래 기준 Commit 의 Source 정보와 대조한다.

항목	내용
주 독자	API 개발자 · 보안담당자 · Gateway 운영자 · 외부 연계 운영자
이 문서로 완료할 일	Gateway 를 설치하고 Route · Predicate · Filter · Rewrite · Target · Discovery · 보안 · Timeout · Retry · Attempt Ledger · Validate · Approve · Publish · ACK/NACK · LKG · Scale-out · Drift · Reconciliation 을 운영한다.
완료 판정	독자가 다른 문서나 Source 역분석 없이 정상 흐름, 오류, 부분 실패, 복구, 감사, 운영 인계를 끝낼 수 있어야 한다.
상태 표현	완료 / 부분 구현 / 미구현 / 미검증 / 실패 / 재확인 필요만 사용한다.
정합성 원칙	실제 Class · API · SQL · Config · 화면 · Permission · Script · Test 를 우선하고 문서와 양방향으로 추적한다.

1. Gateway 선택 기준

외부 Trust Boundary, 중앙 Route 정책, HMAC/Nonce/SSRF/TLS, Target Load Balancing, 외부 Write Attempt, Publish/ACK/NACK/LKG 가 필요할 때 선택한다. 내부 Same-JVM 호출을 모두 Gateway 로 우회하지 않는다.

2. 설치

1. Artifact/Manifest/SHA/Checksum.
2. Policy Store/Secret Provider/Certificate.
3. Public Listener 와 Admin/Probe Listener 분리.
4. Network Zone/Firewall.
5. Route 없는 상태로 기동.
6. Health/Capability/Version.
7. LKG 저장.

3. Server Group · Target · Discovery

필드: groupId, memberId, target URI, weight, zone, health path, TLS profile, enabled, version. 검증: scheme/host/port/path allowlist, member 0 금지, DNS/IP policy, duplicate/version CAS.

Discovery 를 쓰더라도 최종 Target 후보는 SSRF 정책과 TLS policy 를 통과해야 한다.

4. Route · Predicate · Filter · Rewrite

Route 는 listener, method, host/path/header/query predicates, priority, rewrite, header filter, target group, security, resilience, idempotency 를 하나의 Versioned Snapshot 으로 관리한다.

Golden Request 로 실제 Target URI/Header/Body Hash 를 계산해 검증한다.

5. Authentication · Authorization

외부 Client Identity 와 내부 Service Identity 를 분리한다. Issuer/Audience/Subject/Scope/Permission/Expiry/Clock Skew/Key Version 을 검증한다. Gateway 1 차 제어가 업무 Service 의 Data Scope 를 대신하지 않는다.

5.1 Default Deny 공개 원칙

Gateway 는 Service Registry 에 Endpoint 가 존재한다는 이유만으로 외부 공개하지 않는다. **Default Deny** 가 기본이며, 환경에 맞는 Route/Binding 이 검증 · 승인되어 ACTIVE 이고 대상 Gateway Instance 가 해당 Version 을 ACK 한 경우에만 공개 가능한 상태로 판정한다. ADM · BAT · Actuator · Internal Endpoint 는 명시적 예외 근거 없이 외부 Route 대상으로 등록하지 않는다. Retry 는 먹통 Route 에서만 허용하며 비먹통 호출의 응답 유실은 Attempt Ledger 와 Target 원장을 대사한다.

6. HMAC · Audience · Body Hash · Nonce

Canonical String 에는 method, normalized path, canonical query, content SHA-256, timestamp, nonce, audience 를 포함한다.

검증 순서:

1. Key ID/Version.
2. Timestamp/Skew.
3. Nonce replay.
4. Body hash.
5. Canonical string.
6. Constant-time signature compare.
7. 성공 Nonce/Attempt 기록.

Negative: body/path/audience 변경, expired/future timestamp, nonce replay, retired key, client cert mismatch.

7. SSRF · TLS

- 승인 Scheme.
- 등록 Group/Allowlist Host.

- Loopback/link-local/metadata 차단.
- DNS resolve 결과 재검증.
- Redirect Target 재검증.
- 사용자 입력 전체 URL 금지.

TLS 는 protocol/cipher/trust/client cert/hostname/SAN/expiry/revocation 을 관리한다.

8. Timeout Budget

Client Deadline > Gateway Overall > Queue + Connect + TLS + Response + Transform + Ledger

Retry Backoff 도 Overall Budget 안에 포함한다. Write response loss 는 Blind Retry 하지 않는다.

9. Retry · Circuit Breaker · Bulkhead · Rate Limit

- Validation/Auth 오류는 재시도하지 않는다.
- Connect 전 일시 오류만 정책상 Retry.
- 명시 5xx 는 Idempotency/Budget 확인.
- Circuit window/failure/open/half-open probe.
- Bulkhead concurrency/queue.
- Rate limit key/limit/window/response header.

10. Idempotency · Attempt Ledger

저장: route/version, client, idempotency key, request hash, target group/member, attempt no, dispatch time/deadline, target tracking ID, result.

같은 Key+같은 Hash 는 기존 결과, 같은 Key+다른 Hash 는 Conflict.

11. UNKNOWN_RESULT

Dispatch 이후 응답을 잃으면 Attempt 를 UNKNOWN 으로 두고 Target Status Query/업무 Owner 대사로 확정한다.

12. Validate

- 중복 Route/우선순위.
- Predicate/Rewrite 결과.
- Target 존재/Health.
- SSRF/TLS/Secret.
- Timeout 관계.
- Retry/Idempotency.
- Schema/Checksum.
- Golden/Negative Request.

13. Approval·Publish

Approval Snapshot: route version, target, security, timeout, checksum, target list, reason, expiry.

Publish:

1. Operation 생성.
2. Target 별 version/checksum dispatch.
3. ACK/NACK/Timeout 수집.
4. Observed 확인.
5. PARTIAL/DRIFT 분리.
6. 성공 Target 보존.
7. 실패 Target Reapply 또는 LKG Rollback.

14. ACK·NACK·Partial Apply

상태	의미	행동
ACK	적용 성공 응답	Observed/Health 확인
NACK	검증/적용 거부	Error/환경 보정
Timeout	결과 미수신	Applied Version 조회
PARTIAL	혼합 결과	성공 Target 보존
DRIFT	Desired ≠ Observed	Reconcile/Rollback

15. LKG·Rollback

LKG 에는 Route/Target/Security/Timeout/Checksum/Secret Reference Version 을 저장한다. Rollback 도 Target 별 Operation 이며 부분 Rollback 을 별도 상태로 기록한다.

16. Scale-out·Drift·Reconciliation

새 Instance 는 현재 Desired Version 을 받기 전 Traffic 대상이 되지 않는다. Scale-in 시 Drain 후 Registry/Lease 를 제거한다. 주기적으로 Desired/Observed/Checksum/Health 를 비교해 Drift 를 탐지한다.

17. Probe·Health

DNS→TCP→TLS→HTTP→Authentication→Application 단계로 Probe 를 분리한다. Connection Test 자체도 외부 Write 부작용을 만들지 않게 별도 안전 Endpoint 를 사용한다.

18. ADM 운영

Dashboard, Server/Group, Route, Security, Health, Transaction, Log Policy, Apply Status 화면에서 같은 Route/Operation/Target 식별자를 사용한다.

19. 장애 Runbook

Route NACK

Validation Error→Target Config→Secret/Cert→Version/Checksum 순으로 확인하고 수정된 새 Snapshot 으로 재게시한다.

Response Loss

Attempt 조회→Target 상태→Owner 대사→성공/실패/보상 확정.

Partial Apply

성공 Target 보존→실패 Target 원인→Reapply 또는 전체 LKG 정책→최종 Drift 0 확인.

SSRF/TLS 차단

정책을 끄지 말고 Host/IP/Certificate/Trust 설정을 보정한다.

20. Route 게시·응답 유실 통합 실습

Route Draft→Golden Validate→Negative Security Test→Approval→Publish→Target 하나 NACK→PARTIAL 확인→실패 Target 수정→Reapply→Observed 일치→LKG Rollback Drill 까지 수행한다.

21. 완료 체크리스트

- Route/Predicate/Filter/Rewrite 가 Versioned Snapshot 이다.
- Target/Discovery/Load Balancing 이 있다.
- Authentication/Authorization/HMAC/Audience/Nonce/SSRF/TLS 가 있다.
- Timeout/Retry/Circuit/Bulkhead/RateLimit 관계가 있다.
- Idempotency/Attempt/UNKNOWN_RESULT 가 있다.
- Validate/Approval/Publish/ACK/NACK/PARTIAL 가 있다.
- LKG/Rollback/Drift/Reconcile 가 있다.
- Scale-out/Probe/ADM/Runbook/EDU 가 있다.

22. Trusted Proxy · Header Policy

외부에서 들어온 내부용 Header 를 그대로 신뢰하지 않는다. Trusted Proxy Chain 과 Client Header Allowlist 를 적용하고 내부 Identity/Trace Header 는 승인 경계에서 재생성하거나 덮어쓴다.

23. Streaming·Client Disconnect

Request/Response Body 를 스트리밍하는 Route 는 전체 Body 재적재를 피하고 Retry 가능 조건을 제한한다. Client Disconnect, Target Disconnect, Partial Response, Response Body read failure 를 서로 다른 Attempt 단계로 기록한다.

24. Rate Limit·Quota

Client/Channel/API/Tenant 별 rate, quota, burst, distributed counter 를 정의한다. 429 와 Retry-After 의미를 일관되게 제공하고 운영 Override 는 Permission/Reason/Expiry/Audit 를 사용한다.

25. Multi-instance Correlation

비동기/Streaming 응답이나 Target callback 이 인스턴스 로컬 Memory Queue 에만 의존하지 않게 Durable Correlation 을 사용한다. Instance loss/rebalance/late reply 를 재현한다.

26. Gateway Artifact Trust

Route/Policy Artifact 는 version/checksum/signature/keyId 를 가지며 Target 적용 전에 검증한다. 잘못된 Snapshot 은 fail-closed 하고 마지막 승인 LKG 를 유지한다.

27. Gateway 제품과 Reference 경계

Gateway 는 cpf-gateway 가 제공하는 Data Plane/Control Plane 제품이다.

Route·Target·HMAC·SSRF·Retry·Publish·LKG 같은 제품 내부 기능을 Reference Handler 로 다시 구현한 개수는 제품 완료 근거가 아니다. EDU 는 외부 Client 또는 고객 서비스가 실제 Public Contract 를 소비하는 통합 예제일 때만 교육 근거로 사용한다.

28. Route 생명주기

1. Server Group 과 Service Registry 대상의 Health/Version 을 확인한다.
2. Route/Predicate/Rewrite/Filter/Timeout/Retry/Security 정책을 Draft 로 저장한다.
3. Validate 에서 Target, SSRF/TLS, Timeout Budget, Retry 안전성, Schema/Checksum 을 확인한다.
4. 위험 Route 는 Approval ID 와 변경 사유를 확보한다.
5. Publish 요청 후 Gateway Instance 별 Expected/Applied Version 과 ACK/NACK 를 확인한다.
6. 일부 Instance 실패는 성공 Instance 를 되돌려 전체 실패로 꾸미지 않고 Partial Apply 로 기록한다.
7. Drift 또는 NACK Instance 를 재대사하고, 필요하면 LKG 또는 승인된 Rollback 을 수행한다.
8. Audit 에서 Actor·Reason·Route Version·Approval·Instance Apply 결과를 확인한다.

29. transactionId·Attempt 계보

Gateway 는 원 transactionId 를 호출 체인에서 유지한다. Retry/Failover 마다 새 거래 ID 를 만들지 않고 attempt, segmentId/parentSegmentId, traceId/spanId 로 시도를 구분한다. 외부 호출에는 최소 Target Service/Operation, remote request 식별자, timeout budget, result/error/failureStage, UNKNOWN/Reconcile 결과를 연결한다.

ADM 에서 한 transactionId 로 Gateway 구간과 Online/Message/File/Batch 구간을 이어 볼 수 있어야 하며, 수집원이 늦거나 빠진 경우 Partial/Stale 경고 없이 정상 Timeline 으로 표시하지 않는다. 원문 Payload · Token · Credential · PII 는 기록하지 않고 Masking/Redaction/Digest 정책을 적용한다. 이 종단간 Runtime 계보는 현재 R6J 독립 QA 대상이므로 이번 문서 산출물에서는 미검증으로 구분한다.

30. Attempt Ledger 와 응답 유실

- Connect 실패와 Response Timeout 을 같은 결과로 취급하지 않는다.
- 역등 Route 만 정책 범위 내 Retry 를 허용한다.
- 요청을 Target 에 전달한 뒤 응답이 유실된 경우 UNKNOWN_RESULT 를 사용하고 Blind Retry 를 금지한다.
- Attempt Ledger 의 Target, 시각, 상태, 실패단계, Provider/Remote 식별자를 조회한 뒤 Reconcile 한다.
- 결과 확정 후에만 재처리 또는 보상을 결정한다.

31. SSRF · TLS · Trusted Proxy

Route 등록 시 Host/Address/Protocol 을 검증하고 관리/Metadata/Internal 주소를 기본 공개 대상에서 제외한다. TLS 인증서 · Trust Policy · SNI 를 검증하며, 외부 Client 가 보낸 내부 Transaction/Instance/Security Header 를 신뢰 경계 안쪽 값처럼 사용하지 않는다. Trusted Proxy Header 는 승인된 Proxy 경계를 통해서만 채택한다.

32. Scale-out · Canary · Drift

다중 Gateway Instance 에서 적용 성공 여부는 단일 Publish 응답이 아니라 Instance 별 ACK 와 Version 으로 판정한다. Canary/가중치 변경 전 Target Snapshot 을 기록하고, 일부 적용 실패 시 실패 Instance 만 Reconcile 한다. LKG 는 마지막으로 검증 · 승인되어 적용 가능하다고 판정된 구성으로 제한한다.

33. Gateway 운영 인수 Gate

- Server Group/Discovery/LB, Route/Predicate/Filter/Rewrite 가 실제 Control Plane 계약과 일치한다.
- AuthN/AuthZ/HMAC/TLS/SSRF, Timeout/Retry/Circuit/Bulkhead/Rate Limit 이 Route 별로 명시된다.
- Idempotency/Attempt/UNKNOWN_RESULT 와 응답 유실 대사가 연결된다.
- Validation/Approval/Publish, ACK/NACK/Partial Apply, LKG/Rollback, Drift/Reconcile 을 운영자가 수행할 수 있다.
- transactionId 기반 계보에 Gateway attempt 와 외부 호출 결과가 연결된다.
- Runtime multi-instance ACK/NACK, failover, transaction lineage 를 직접 실행하지 않은 항목은 미검증으로 기록한다.
- EDU 개수를 제품 완료 기준으로 사용하지 않는다.

34. 현재 제품 검증 상태와 R6J 사용 경계

판정 기준: master cd5baccb02245a980e5998aa0dc9bac579fc019f (07_04), R6J QA basis 3ed676061246c9db3e44f29e254c0393ecca3929 (07_02). 07_04 Commit 은 전체 프로젝트 100% Finalization Mandate 와 QA Scope 보정을 추가했으며 R6J 검수 대상 Product Source 는 07_02 와 동일하다.

- 07_04 정책에 따라 34 개 직접 Rework 는 전체 개발 Scope 가 아니다. 중앙 Requirement 93/93, Finding 56/56, 최상위 Requirement 전체, Runtime/GA 전체와 작업 중 자체 발견 결함까지 프로젝트 완료 범위로 본다.
- Gateway 제품 기능은 Reference 예제 수로 완료 판정하지 않는다.
- 현재 중앙 QA 는 UNKNOWN-producing Owner 의 observation reconcile 을 Gateway 포함 각 Owner 에서 요구하며, multi-instance/response-loss/process-kill target runtime 은 미검증이다.
- Publish ACK/NACK/PARTIAL 또는 응답 유실 후에는 동일 operation/transaction 식별자로 실제 Data Plane 상태를 관측해 reconcile 하고, 결과 불명 상태에서 무조건 재게시하지 않는다.
- 현재 문서는 Route/보안/Publish/LKG 절차의 계약 기준이며 Release 승인 증거는 후속 exact-SHA runtime qualification 에서 별도로 확보한다.

이 문서에 직접 영향을 주는 R6J 재개발 항목: 2 개. 아래 항목이 후속 exact SHA 에서 닫히기 전에는 해당 기능을 Release 승인 근거로 사용하지 않는다. 이 표는 문서 영향 매핑이며 전체 프로젝트 Scope 를 제한하지 않는다.

ID	우선순위	영역	현재 조치 기준
AB-R6-025	P0	Runtime/Release	Owner success 후 DB finalization 장애 시 durable UNKNOWN 보장 부족
R6J-CENTRAL-NEW-012	P0	Approval/Recovery	UNKNOWN-producing Approval Owner 의 observation reconcile 누락

정상화 판정은 Source 존재가 아니라 실제 Consumer · 권한 · 실패 · 동시성 · 복구가 current exact SHA 에서 실행되고, generated diff 0 과 Evidence hash 가 결속된 결과로 한다.